

ISO27001（ISMS）の取得に向けて

1. 概要

ISMSは、組織の情報を保護する為に、「機密性・完全性・可用性」の保護を体系的に行う手段の一つです。
ここでは、情報機器やサービスに焦点を当てて紹介します。

2. ISMSの取得と維持の為に

まずISMSの取得の為に、「組織の現状を把握」し、「情報セキュリティポリシーを策定」。
そして、実際に運用していく為の「組織体制を構築」します。
準備が整ったら、「リスクアセスメントを実施」し、また「セキュリティ対策を実施」します。
これらの「運用・監査体制を構築」し、適切な運用が行われることが必要です。
また、取得後は維持していく為に、年に1度程度の維持審査や、3年に1度の更新審査が必要です。

3. 情報機器やサービスを活かす

では、情報機器やサービスはISMSをどう役立てるのか、考えてみます。

a.組織の現状把握、情報セキュリティポリシーの策定

情報資産を分別し、その価値を評価します。また、情報資産の運用や保管状況を把握できなければいけません。
紙の資料が点在していたり、各社員が個別にメールやUSBで情報をやり取りしては、情報資産の現状把握や運用・保管状況の把握がとても難しいです。
そこで、情報資産が余計な複製をされないように一元的に管理し、運用できる仕組みが有効です。
業務用のNASやクラウドストレージを利用することで、情報資産は1箇所に集約され、バックアップや保護も容易に。
オリジナルのデータが共有されることで更新された情報が混在することはありません。
また共有リンク機能を活用すれば、添付メールによる無自覚なファイルのコピー乱造も防ぎ、外部との共有も安全かつ容易です。
こうした管理・運用を策定することで、ISMSの取得後に運用・維持にかかる時間と手間の大幅な削減が期待できます。

b.リスクアセスメントの実施

リスクアセスメントは、
「情報資産の特定」「脅威と脆弱性の特定」「リスクの評価」「リスク対応策の検討」「リスク対応計画の策定」といった手順で構成されています。
紙などアナログの情報資産が多い程、把握と評価にかかる労力は膨大なものになります。
OCRによる紙資料のデジタルデータ化で、資料の検索が容易になり、紛失や覗き見といったリスクを軽減できます。
また複合機とNASやクラウドストレージを連携させれば不要な紙資料の排出を抑え、リスクとコストを継続的に軽減できます。

c.セキュリティ対策を実施

紙資料等であれば、保管場所と体制、密閉空間の確保、施錠と入退室の管理、万が一の火災や盗難への対策が必要となります。
これらの問題もデジタルデータであればコストと労力は大きく抑えられます。
NASやクラウドストレージはアクセス権限とバックアップがセットになっている場合が多く、ログも残ります。
NASでもパスワードや暗号化によって盗難に強く、クラウドストレージならば盗難や紛失、警備体制の心配がありません。
デジタル情報資産は経路が限られている為、UTMやセキュリティハブ、アクセスポイントやUSB管理といった手段を用意できます。
守るべき範囲と手段の効果がはっきりしている為、リスクアセスメントを含めて有効です。

d.運用・監査

ISMSの審査を無事通過しても、そこで終わりではありません。
定期的に審査を行うことで、組織の情報が保護されていることを証明する必要があります。
業務用のルーター、UTMやNASといった自動的にログが残る機材を使用することで、現状把握や万が一の事故が起きた場合の原因究明に備えることができます。
また、セキュリティ機器を適正に運用する為に必要な担当者の労力についても、運用と監視をリモートで行えるサービスを利用すれば継続的な運用状況の監視や、専門的な知識・技術の習得といった負担を軽減することができます。

4. ISMSクラウドセキュリティ認証（ISO/IEC 27017）に備えて

近年、企業がクラウドサービスを利用するケースは増えています。
そこで、ISMSクラウドセキュリティ認証が用意されました。
これは、クラウドサービスを提供する組織だけではなく、利用する組織も認証の対象になります。
今後もクラウドサービスの展開は更に広く大きくなっていく事が予想されます。
クラウドストレージやクラウド会計、添付メールの代替として使用するファイル転送サービス等、需要は大きくなっています。
この機会に併せて備えておくことは無駄にならないと考えられます。

5. ISMS-PIMS（プライバシー情報マネジメントシステム）認証

ISMS認証を取得した組織が取得することができる認証制度です。
組織としての情報資産だけではなく、PII（個人識別可能情報）、いわゆる個人情報もISMS認証に適合して保護・運用されているという認証を得られます。
取引先や顧客に対する信頼向上にも大きく寄与することが期待されます。

6. 最後に

情報資産の重要度や量が増加するにつれて、備える側が把握しなければならない範囲も広がっています。組織が扱う情報資産の量や範囲は年々増加しており、それに伴って求められる情報セキュリティへの備えは、高度で煩雑なものになってきました。扱わなければならない情報資産の重要度や量が増加するにつれて、備える側が把握しなければならない範囲も広がっています。
利便性の向上や国際基準への適応の為に進められるDX化を考えれば、この流れは止まることはないでしょう。
こういった国際規格への対応は、将来必要となる基準への備えとして有効だと思われます。
そこで組織や担当者にかかる負担を軽減し、運用の導入・維持を助けるために、各種の情報機器やサービスは有効です。
信頼のおける企業を窓口にする事で、複雑な組み合わせと運用が求められる各種の情報機器やサービスも、一つの運用システムとして導入することで手間を減らし、表に出にくい保守上のコストも抑えられます。
どうぞ遠慮なくご相談ください。

